

Personuppgiftsbiträdesavtal (PUB) — utkast

Mellan **Helsingborgs stad, Arbetsmarknadsförvaltningen** (org.nr 212000-1157) ("Personuppgiftsansvarig", PUA)
och

PathfinderAI (enskild firma, innehavare Oliver Pettersson, org.nr [FYLLS I]) genom tjänsten **CVmatchen**
("Personuppgiftsbiträde", PUB)

Not om företagsform: PathfinderAI drivs i dag som enskild firma. Registrering av aktiebolag (PathfinderAI AB) planeras inför ett skarpt avtal — bland annat för att stärka ansvars- och kontinuitetsfrågan gentemot kommunen (se punkt 12 och avsnitt om kontinuitet). Avtalspart justeras till aktiebolaget om/när det är registrerat.

Avtalsdatum: [FYLLS I] Avtalsperiod: [FYLLS I — kopplat till pilotavtalets period] Version: 1.0 — utkast 2026-06-17

Detta utkast följer strukturen i SKR:s mallavtal för personuppgiftsbiträde och GDPR artikel 28. Använd kommunens egen mall om sådan finns — texten nedan är förslag på innehåll, anpassad för CVmatchens specifika behandling.

1. Bakgrund och syfte

Helsingborgs stad har anlitat PathfinderAI för att leverera tjänsten CVmatchen — en webbaserad plattform där arbetssökande skapar CV, matchar mot lediga tjänster och får handledning från arbetsmarknadshandläggare.

För att tjänsten ska fungera måste PathfinderAI behandla personuppgifter för Helsingborgs stads räkning. Detta avtal reglerar villkoren för den behandlingen i enlighet med GDPR (Förordning EU 2016/679) artikel 28.

2. Föremål för behandlingen

PathfinderAI behandlar personuppgifter enbart för att leverera CVmatchen till Helsingborgs stad och dess deltagare. Behandlingens art, syfte, varaktighet och kategorier framgår av **Bilaga A — Specifikation av behandlingen**.

3. PUA:s instruktioner

PUB får endast behandla personuppgifter i enlighet med PUA:s dokumenterade instruktioner enligt detta avtal och dess bilagor. Avvikande instruktioner ska bekräftas skriftligen.

PUB ska omedelbart informera PUA om PUB anser att en instruktion strider mot GDPR eller annan tillämplig dataskyddslagstiftning.

4. Säkerhetsåtgärder

PUB ska vidta lämpliga tekniska och organisatoriska åtgärder för att skydda personuppgifterna mot obehörig eller olaglig behandling och mot förlust, förstörelse eller skada genom olyckshändelse.

Vidtagna åtgärder framgår av **Bilaga B — Säkerhetsåtgärder**, som ska hållas uppdaterad under avtalstiden.

5. Underbiträden

PUA ger PUB ett generellt förhandsgodkännande att anlita underbiträden för behandlingen, under förutsättning att PUB tillser att underbiträdena är bundna av motsvarande skyldigheter som följer av detta avtal.

Aktuella underbiträden vid avtalets ingående framgår av **Bilaga C — Underbiträden**. PUB ska skriftligen informera PUA minst 30 dagar i förväg om planerad tillkomst eller utbyte av underbiträde, varvid PUA har rätt att göra invändning. Vid invändning ska parterna gemensamt försöka hitta en lösning.

6. Tredjelandsoverföring

PUB får inte överföra personuppgifter till tredjeland (utanför EU/EES) utan PUA:s uttryckliga skriftliga samtycke. Vid avtalets ingående sker **ingen överföring till tredjeland** — samtliga underbiträden är etablerade och behandlar uppgifter inom EU/EES.

7. Personalens tystnadsplikt

PUB ska säkerställa att de personer hos PUB som behandlar personuppgifterna har förbundit sig att iaktta sekretess eller omfattas av lämplig lagstadgad tystnadsplikt.

8. Bistånd till PUA

PUB ska, mot ersättning för faktiska kostnader, bistå PUA med:

- att besvara förfrågningar från registrerade gällande deras rättigheter (artikel 12–22 GDPR — tillgång, rättelse, radering, begränsning, dataportabilitet, invändning).
- att fullgöra PUA:s skyldigheter enligt artikel 32–36 GDPR (säkerhet, anmälan av personuppgiftsincident, konsekvensbedömning, förhandssamråd).

CVmatchen exponerar för registrerade direkt i tjänsten: - “Exportera mina data” i profilmernyn (artikel 15 & 20) - “Radera mitt konto” i profilmernyn (artikel 17) - Inställningar för AI-samtycke som kan återkallas (artikel 7.3)

9. Personuppgiftsincident

PUB ska utan onödigt dröjsmål och senast inom **24 timmar** från upptäckt informera PUA om varje personuppgiftsincident.

Anmälan ska innehålla: - Incidentens art (vad, när, hur) - Kategorier och uppskattat antal berörda registrerade - Sannolika konsekvenser - Vidtagna eller planerade åtgärder - Kontaktperson hos PUB

PUB åtar sig att bistå PUA i alla aspekter av incidenthanteringen, inklusive anmälan till IMY (Integritetsskyddsmyndigheten) och berörda registrerade när så krävs.

10. Granskning och revision

PUA har rätt att granska PUB:s efterlevnad av detta avtal genom: - Begäran om dokumentation och rapporter - På plats-revision med minst 14 dagars varsel, högst en gång per år utan särskild anledning - Tredjepartsrevision (PUB:s genomförda penetrationstest, SOC 2-rapport eller motsvarande)

PUA bär sina egna kostnader för granskning. PUB:s tid faktureras enligt gällande timpris.

11. Återlämning och radering

Vid avtalets upphörande ska PUB, enligt PUA:s val:

- återlämna samtliga personuppgifter till PUA i ett strukturerat, allmänt använt och maskinläsbart format, eller
- radera samtliga personuppgifter samt befintliga kopior, förutom om lag kräver fortsatt lagring.

PUB ska skriftligen bekräfta att radering skett. Avtalet upphör inte att gälla förrän bekräftelse erhållits.

12. Ansvar

PUB:s ansvar för skada till följd av brott mot detta avtal är begränsat till [fylls i — vanligen 12 månaders avgifter eller fast belopp].

Begränsningen gäller inte vid uppsåt eller grov oaksamhet.

13. Avtalstid och uppsägning

Avtalet träder i kraft vid undertecknande och gäller så länge huvudavtalet (pilotavtalet för CVmatchen) är i kraft. Vid huvudavtalets upphörande gäller bestämmelserna om återlämning/radering i punkt 11.

14. Övriga bestämmelser

- Ändringar i detta avtal ska vara skriftliga och undertecknade av båda parter.
- Vid motstridighet mellan huvudavtalet och detta PUB gäller PUB.
- Tvist ska i första hand lösas genom förhandling, i andra hand i svensk allmän domstol med Helsingborgs tingsrätt som första instans.

Underskrifter

För **Helsingborgs stad, Arbetsmarknadsförvaltningen**:

Namn: _____ Befattning: _____ Datum: _____ Underskrift: _____

För **PathfinderAI**:

Namn: Oliver Pettersson Befattning: Innehavare / grundare Datum: _____ Underskrift: _____

BILAGA A — Specifikation av behandlingen

A.1 Föremål och syfte

Behandling av personuppgifter inom ramen för tjänsten CVmatchen för att stödja kommunens arbetsmarknadsverksamhet — CV-skapande, jobbmatchning, intervjuträning, uppföljning av deltagare.

A.2 Behandlingens varaktighet

Pilot: 3 månader. Därefter förlängning vid direktupphandling.

A.3 Behandlingens art och syfte

- Lagring av deltagares CV-data, träningsprogress, sökta arbeten
- AI-baserad textgenerering (CV-förslag, intervjufeedback, matchning)
- Kommunikation mellan handläggare och deltagare via tilldelade uppgifter
- Rapportering och statistik för kommunens uppföljning

A.4 Kategorier av personuppgifter

- **Identifierande**: namn, e-post, telefonnummer (frivilligt)
- **Yrkesmässiga**: arbetslivserfarenhet, utbildning, kompetenser, körkort, certifikat, språkkunskaper
- **Användningsdata**: inloggningstillfällen, klick i appen, tilldelade uppgifter och status, sparade jobbbannonser,

intervjuseSSIONER

- **AI-konversationer:** text som deltagaren skrivit/sagt under intervju träning (pseudonymiserade)

A.5 Inga särskilda kategorier

Tjänsten behandlar inte uppgifter om hälsa, etnicitet, religiös tro, politisk åskådning, sexuell läggning, biometri eller liknande särskilda kategorier (artikel 9 GDPR).

A.6 Kategorier av registrerade

- Arbetssökande deltagare anvisade av Arbetsmarknadsförvaltningen
- Handläggare och administratörer hos PUA

BILAGA B — Säkerhetsåtgärder

B.1 Tekniska åtgärder

Transport - TLS 1.3 med HSTS preload på alla anslutningar - Inga okrypterade kanaler

Autentisering - Deltagare: e-post + engångskod (OTP, 6 siffror, 5 min giltighet) - Handläggare: Microsoft EntraID OAuth + invite-token vid första login - HMAC-SHA256-signerade sessionstokens, 24h giltighet - Inloggningsförsök loggas

Auktorisering - Row-Level Security (RLS) i Postgres - Multi-tenant-isolation per kommun/enhet - Service role-nycklar används endast serverside efter admin-verifiering

Lagring - Kryptering at rest (AES-256, Supabase managed) - Backup dagligen, 7 dagars retention, point-in-time recovery

Loggning & övervakning - Sentry för felövervakning - admin_audit-tabell för spårbarhet av admin-åtgärder - Vercel-loggar (rullande)

Säkerhetsgranskning - Intern DOM-XSS-revision genomförd juni 2026 - OAuth-callback-säkerhet (host-header-injection) granskad - Penetrationstest planerat Q3 2026

B.2 Organisatoriska åtgärder

- Singel-utvecklare med privat Github-repo, branch-protection på `main`
- Inga produktionsdata i utvecklingsmiljö
- Tystnadsplikt enligt anställningsavtal
- Incidenthanteringsrutin med 24h-anmälningsfrist till PUA

BILAGA C — Underbiträden

Underbiträde	Tjänst	Etableringsort	Behandlingsregion	Funktion
Vercel Inc.	Hosting + serverless compute	USA*	Stockholm (arn1)	Webbservern + API-endpoints
Supabase Inc.	Postgres-databas + auth	USA*	Frankfurt (eu-central-1)	All lagring av personuppgifter
AWS (Amazon Web Services)	Bedrock — AI-inferens	USA*	Frankfurt (eu-central-1)	AI-textgenerering (Claude-modeller)
Resend Inc.	Transaktionsmejl	USA*	EU	Inbjudningar, OTP-koder
Sentry	Felövervakning	USA*	EU	Tekniska felmeddelanden (ej PII)

*Bolagets juridiska säte är i USA men all data-behandling sker inom EU/EES enligt deras EU-regionsval. Standard Contractual Clauses (SCC) är inte nödvändigt eftersom ingen tredjelandsoverföring sker.

PUB:s underleverantörsavtal med dessa parter inkluderar DPA enligt respektive standards (Vercel DPA, Supabase DPA, AWS

GDPR DPA, etc.). Kopia kan tillhandahållas på begäran.

Detta utkast bör granskas av Helsingborgs stads dataskyddsombud och jurist innan undertecknande. Klausuler om ansvar, vite och uppsägning kan behöva anpassas efter kommunens upphandlingsregler.